ASSESSMENT / GOD'S EYE VIEW

A24 戰情台安全評估報告

紅隊導向攻擊面分析與原生 macOS 受控驗證

評估未完成 · 無發布放行

INCOMPLETE — NO RELEASE AUTHORIZATION

文件版本
1.0.0

資料截止
截至 Review 45 與 2026-11-09 後續交接文件勘誤

受評 Commit
e50944f89f99b60d948ede8e4f0a9feee12cd3a7

產品工作樹
Dirty：保留三份歷史 tracked pyc 刪除

執行邊界
原生 macOS · 選項 A · 2 CPU

具名風險責任 / 簽核
待指定；未核准發布

報告交付與驗證限制

報告內容整理、來源核對、合成互動及靜態圖像檢查已完成。瀏覽器管道不可用，桌機 / 手機實際排版、原生鍵盤操作、真瀏覽器CSP與列印仍未驗證；A4輸出僅以獨立排版工具檢視，不代替瀏覽器驗收。

查看介面 QA 範圍

JavaScript 已停用。全部主文仍可閱讀；證據預設展開，可使用瀏覽器搜尋與列印。

01 / DECISION

管理摘要

目前判斷

本次評估已確認一項 Grounding 邏輯缺陷，並取得部分本機准入、PAT 生命週期、代理隔離、取消恢復及受控建置的驗證證據。三項候選風險仍需釐清部署前提與產品契約。完整主 App、目前受控瀏覽器流程及必要自動化掃描尚未完成，現有證據不足以支持整體安全驗收或發布放行。

證據 SRC-003 · SRC-005 · SRC-006 · SRC-007

已確認問題

GEV-F-001 的船舶數量驗證允許集合包含固定值 5。當合成資料中實際只有 2 艘船舶時，回答「目前共有 5 艘」仍能通過檢查。此問題削弱回答可信度保護，可能誤導態勢判讀；目前沒有證據支持秘密外洩、權限提升或實際業務損害。缺陷維持 CONFIRMED / OPEN，風險等級與 CVSS 待評，未套用修補。

證據 SRC-007 · SRC-008 · SRC-009 · SRC-010

有效的防禦證據

指定測試已觀察到不合格請求遭拒、PAT 輪替及撤銷後舊權杖失效、部分代理請求受限制，以及取消後的鎖釋放與恢復。這些結果適用於各自的真實入口、合成替身與控制條件，不代表所有路由、部署方式或真模型均通過。

證據 SRC-005 · SRC-016 · SRC-018 · SRC-020 · SRC-021 · SRC-023 · SRC-025

仍待確認的風險

C-002 關注上游回應缺少累積位元組上限；C-003 關注 PAT 父目錄鏈與本機使用者信任；C-004 關注代理敏感路由的責任及副作用邊界。已知程式行為不足以直接證明可利用的阻斷服務、跨使用者越權或完整授權繞過，因此三者維持 NEEDS VALIDATION。

證據 SRC-007 · SRC-011 · SRC-012 · SRC-006

主要限制

Standalone 在原 2 CPU 預算下超限終止，沒有可驗收成品；Panel 的保留成品與離線評估只支持該建置子集。Chrome 診斷治具正常收尾，但瀏覽器本身 Target closed。Semgrep、Gitleaks、OSV-Scanner 的必要離線供給未備妥，Docker 實體容器與真實模型、上游仍未完成驗證。

證據 SRC-003 · SRC-006 · SRC-028 · SRC-029 · SRC-030 · SRC-034 · SRC-038

需要的決策

後續需由有權維護者決定 F-001 修補與回歸工作、指定候選議題的責任人並確認部署契約，以及補齊可核實的離線工具。選項 A 已定，維持 2 CPU、原生 macOS；不再要求 3 CPU、另一 OS VM 或重跑相同結果。報告不代替風險接受或發布決策。

證據 SRC-003 · SRC-006

02 / SCOPE

範圍與方法

受評對象與資料截止

對象為 A24 戰情台（1151104_gods-eye-view）。受評 commit 為 e50944f89f99b60d948ede8e4f0a9feee12cd3a7；保留三份歷史受追蹤 pyc 刪除，因此工作樹為 dirty，不描述成 clean。報告整理範圍截至 Review 45 與 2026-11-09 後續交接文件勘誤，不把報告產製日期當成新測試時間。

證據 SRC-003 · SRC-006

任務定位

本次採紅隊導向檢視攻擊面與信任邊界，方法以程式碼審查、合成輸入、單元 / 處理常式測試、部分真實 HTTP、作業系統隔離與建置子集為主。未形成完整初始入侵、權限提升、橫向移動及偵測回應演練，不能據此評估企業整體攻防能力。

證據 SRC-001 · SRC-002 · SRC-005

授權與執行界線

沿用原 ROE 與 NATIVE-01，在原生 macOS、受控來源副本及合成資料下執行；不得擅改產品、依賴、設定或 F-001。不得讀取真憑證、真 .env、Keychain 或既有瀏覽器 Profile，不連真模型及外部上游。本報告製作只整理既有檔案，不新增產品執行或安全測試輪次。

證據 SRC-002 · SRC-003 · SRC-006

資源控制的精確語意

NATIVE-01 採反應式觀測及超限停止：名義 50 ms 取樣、500 ms 程序群平均 CPU 視窗，搭配已觀測 CPU 工作量、RSS、工作容量與 wall time。2 CPU 是觀測目標，不是核心排程器硬性配額。短命行程、排程延遲、停止前超額與資料下界仍有限制，不宣稱固定最壞停止上界；工作容量也不等於累積 SSD 寫入量。

證據 SRC-002 · SRC-003 · SRC-039

測試層級與替身

每筆結果依真實產品入口、被替換的 client / retriever / 上游、傳輸方式及觀測範圍判讀。處理常式上合成 remoteAddress 僅證明准入邏輯，不證明真實 LAN 拓樸；PassThrough 串接不等於獨立網路服務；虛擬時鐘不等於經過相同長度的真實流量。

證據 SRC-001 · SRC-005 · SRC-021 · SRC-023 · SRC-025

來源優先與衝突處理

原 test-matrix.md 決定情境身分與分母；最新採認及勘誤決定當前判讀；原始結構化結果與遮罩日誌提供觀測值。已撤回摘要不作新結論，歷史失敗不被後續成功覆寫。來源 hash 是本次檔案完整性快照，不是數位簽章，也不能反向證明所有歷史執行狀態。

證據 SRC-001 · SRC-003 · SRC-005 · SRC-012 · SRC-013 · SRC-015 · SRC-016

判讀與交付限制

缺陷確認程度、風險等級、處置狀態、測試結果與證明層級分開呈現。Ledger CLEAN 只表示所報帳本完整性，SDD 結案只表示工作完成，兩者均不代表產品安全。單檔報告將保留必要安全節錄與來源索引；完整原始證據需在原資料夾結構下查閱，不會把 raw 日誌全文嵌入。

證據 SRC-001 · SRC-003 · SRC-006

03 / BOUNDARIES

攻擊面與信任邊界

圖解閱讀方式

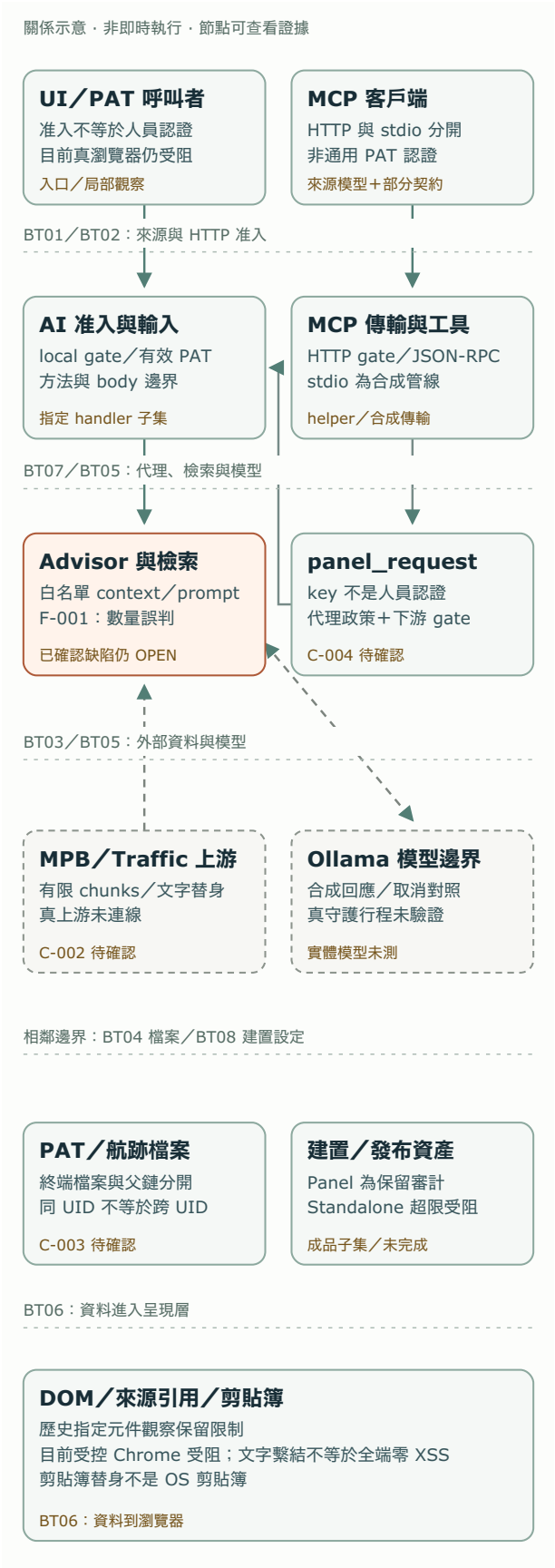
圖中的BT編號沿用原威脅模型；線條表示產品架構或指定子集的呼叫關係，不是攻擊成功路線。虛線外部關係的動態測試使用替身，沒有真上游或模型連線。檔案、發布與DOM另列為相鄰邊界。

點選節點可查產品入口、證據與限制。圖下文字對照保留完整說明，動畫預設停止；減少動態設定與列印時維持靜態。

證據 SRC-045 · SRC-005 · SRC-003

攻擊面與信任邊界

來源模型與指定測試的關係圖。箭頭表示資料或呼叫方向，不表示成功入侵。底部檔案、發布及呈現區是相鄰邊界，並非順序攻擊鏈。



動畫僅示意指定入口的請求方向；不是即時流量或新的測試。

實線：已測入口子集或架構關係 | 虛線：真外部服務未驗證 | 動畫：概念示意，不是測試證據

證據 SRC-045 · SRC-005 · SRC-003

節點文字對照與證據

UI / PAT 呼叫者 · 入口 / 局部觀察

本機UI及PAT請求會到AI入口；Host、Origin及local gate的指定案例已有觀察，不能據此宣稱所有瀏覽器 / 部署通過。

產品入口 / 元件：/api/taiwan-ai-advisor · /api/taiwan-ai-status

證據 SRC-045 · SRC-016 · SRC-003

MCP 客戶端 · 來源模型 + 部分契約

HTTP MCP使用自身local gate；stdio啟動及apiBase屬操作者信任邊界。不能把兩者視為同一認證或讓模型直接派發工具。

產品入口 / 元件：/mcp · serveStdio

證據 SRC-045 · SRC-005 · SRC-018

AI 准入與輸入 · 指定 handler 子集

AI的本機管理准入與PAT推論 / status權限不同；Token管理需本機准入。具指定負向與生命週期結果，不代表全部路由。

產品入口 / 元件：/api/taiwan-ai-token · isLocalBrowser

證據 SRC-045 · SRC-016 · SRC-021

MCP 傳輸與工具 · helper / 合成傳輸

既有HTTP helper與PassThrough serveStdio驗證適用其替身與觀測限制；獨立CLI、完整catalog與實際拓樸尚欠。

證據 SRC-045 · SRC-018 · SRC-023

Advisor 與檢索 · 已確認缺陷仍 OPEN

真實runOllama / 合成client等子集證明特定契約，grounding允許固定5導致2艘上下文的錯誤5艘回答被接受；未連真模型。

產品入口 / 元件：buildPrompt · validateGrounding

前往相關發現 / 證據節錄

證據 SRC-007 · SRC-008 · SRC-005

---

panel_request · C-004 待確認

Panel key可由讀panel resource的MCP client取得；代理只轉送白名單headers並受下游gate。指定負向防護不是全路由授權證明。

產品入口 / 元件：src/tools/queries/panelRequest.js

前往相關發現 / 證據節錄

證據 SRC-044 · SRC-020 · SRC-025

MPB / Traffic 上游 · C-002 待確認

固定來源資料經接收、解析、快取與檢索。缺body cap的架構事實不等於已利用DoS；圖中上游關係來自來源模型，動態觀察只用合成替身。

前往相關發現 / 證據節錄

證據 SRC-045 · SRC-042 · SRC-043 · SRC-012

Ollama 模型邊界 · 實體模型未測

Prompt與模型回覆有來源資料流；既有測試使用合成fetch / client或串流替身。箭頭不表示已連線真模型，更不表示模型取得工具執行權。

證據 SRC-045 · SRC-005 · SRC-020

PAT / 航跡檔案 · C-003 待確認

PAT終端O_NOFOLLOW / 0600與航跡檔案行為分別已有指定觀察；父目錄symlink及跨UID信任仍須部署契約，未讀真權杖。

前往相關發現 / 證據節錄

證據 SRC-045 · SRC-041 · SRC-020

建置 / 發布資產 · 成品子集 / 未完成

Panel保留722檔成品與離線評估，不能替代Standalone或全產品秘密掃描；此區為相鄰發布攻擊面，不代表資料依序流入建置。

前往相關發現 / 證據節錄

證據 SRC-029 · SRC-034 · SRC-038

DOM / 來源引用 / 剪貼簿 · **BT06**：資料到瀏覽器

呈現層接收API與模型文字；真瀏覽器、全域其他sink與OS剪貼簿安全不能由單元資料推定。此框獨立列出，不暗示前述建置或檔案依序流入DOM。

證據 SRC-045 · SRC-005 · SRC-003

04 / FINDINGS

安全發現

確認程度、風險等級與處置狀態分開記錄。候選風險不是已確認漏洞。

GEV-F-001

已確認

硬編碼船舶數量使錯誤回答通過 grounding

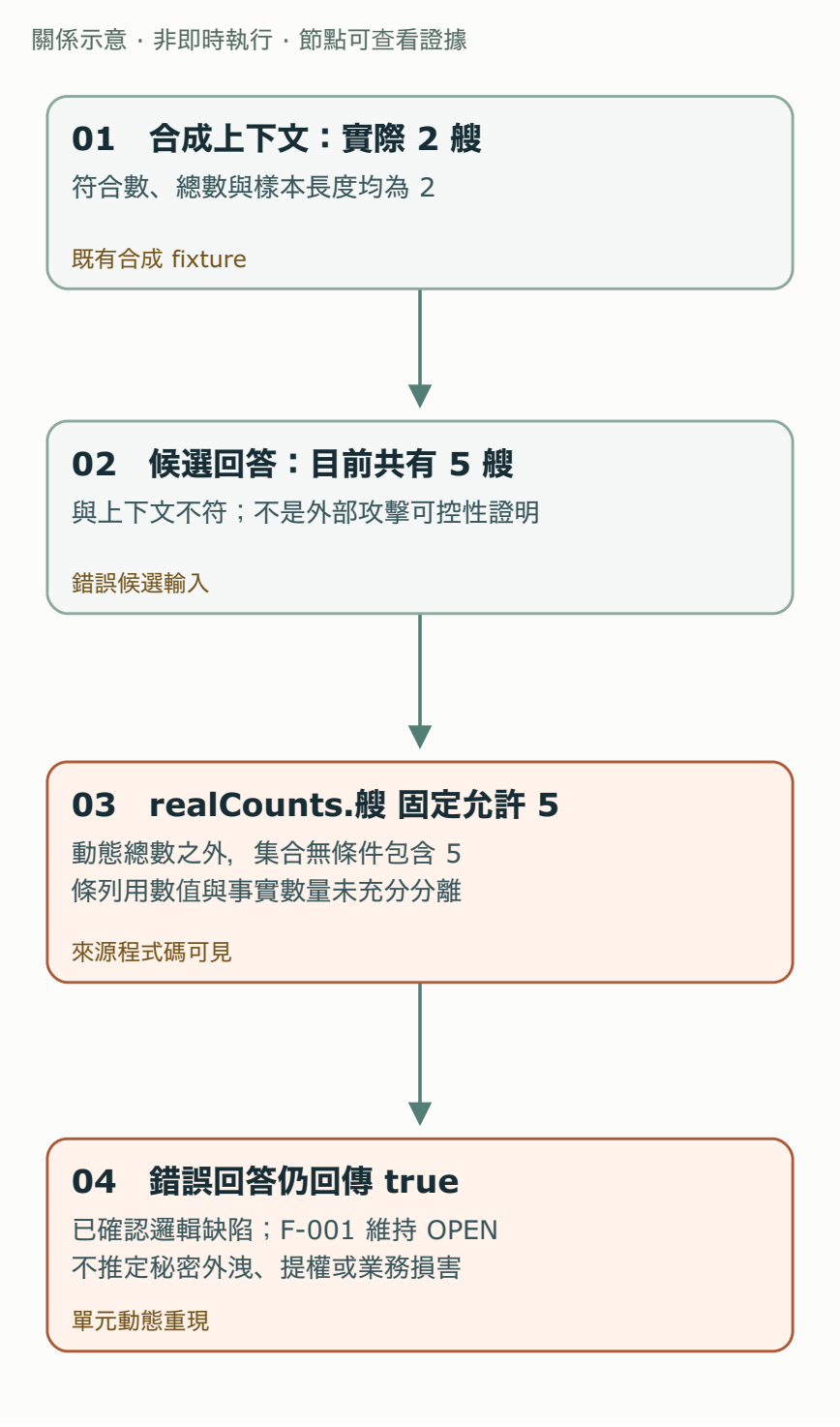
未修補 | 風險等級待評 | 責任人待指定

Grounding把固定列舉值與事實數量混在允許集合中，使錯誤船數被接受。

> 分級依據
>
> 缺陷已確認，但實際暴露、模型輸出可控性與業務決策用途不足，不能推導可靠嚴重度或CVSS。

F-001：錯誤船數如何通過驗證

既有證據重建，不是本次新測試或真模型實況；下圖將合成上下文、錯誤候選、程式條件與函式結果分開。



動畫僅輔助解釋既有誤判因果，不表示即時執行。

實線：已測入口子集或架構關係 | 虛線：真外部服務未驗證 | 動畫：概念示意，不是測試證據

證據 SRC-007 · SRC-008 · SRC-009 · SRC-010

節點文字對照與證據

01 合成上下文：實際 **2** 艘・既有合成 **fixture**

Context來自既有單元重現，不是真實即時船位。

前往相關發現 / 證據節錄

證據 SRC-009

02 候選回答：目前共有 **5** 艘・錯誤候選輸入

既有重現以錯誤5艘候選測試函式，未證明遠端主體能強制真模型輸出。

前往相關發現 / 證據節錄

證據 SRC-009 · SRC-007

03 **realCounts.艘** 固定允許 **5**・來源程式碼可見

程式碼第76–83行固定值5出現在允許集合中。

前往相關發現 / 證據節錄

證據 SRC-008

04 錯誤回答仍回傳 **true**・單元動態重現

早期Attempt02結果true，適用該輪控制限制；後續子集觀察不取代未測部署。

前往相關發現 / 證據節錄

證據 SRC-009 · SRC-010 · SRC-007

受影響元件

- server/providers/ai/ollama-client.js：validateGrounding，尤其第76–83行

成立前提

- AI請求通過local gate或有效PAT。
- 候選回答完成且未超出輸出上限；模型可能產生不準確文字。

已證實事實

- realCounts.艘將動態來源數量與固定5一併加入。

- 既有合成上下文總數 / 符合數 / 樣本長度皆2；2艘回答通過、3艘回答拒絕、5艘錯誤回答仍通過。

既有重現紀錄

以下整理歷史觀察，本次未重跑產品。

1. 使用既有合成上下文，令matched_total.vessels、summary.total_vessels、樣本長度均為2。
2. 比較「目前共有2艘」、「目前共有3艘」、「目前共有5艘」的validateGrounding結果。
3. 保留歷史true / false / true觀察及其複核限制；本次只整理，不重跑。

影響判讀

已觀察：對事實船數不符的候選回答發生驗證誤判。

有條件影響：若使用者依賴此結果判斷態勢，可能誤信錯誤數量。

尚未證明

- 外部攻擊者可強制模型產生特定答案
- 秘密外洩、權限提升、RCE或實際業務損害

證據限制

- 早期單元重現有前置 / BP控制缺口，後續產品子集也須套用各輪採認限制。
- 未連真模型，沒有已部署成品或實際決策損害證據。
- 「前5艘」語法被接受不代表樣本只有2艘時整句語意正確。

改善建議

- 將條列上限、總數與篩選數分開驗證，移除無條件固定5放行。
- 依查詢語意使用對應結構化資料；無法確認時採明確fallback。
- 取得修改授權後提出patch與回歸案例；目前不修改產品。

驗收條件

- 在真實總數2時，錯誤5與3均觸發拒絕或規定fallback，正確2仍通過。
- 使用數個不同真實總數，分別測總數、篩選數與「前N艘」語意。
- 核准範圍內驗證runOllama / middleware相依行為，確認修補成品與來源一致，經複核後才可關閉。

查看 **5** 段安全證據節錄

船舶數量允許集合包含固定值**5**

EV-F001-CODE · 第 76–83 行

```
  const realCounts = {
□□□□□: new Set(
```

```
      [
        matched_total.vessels,
        summary.total_vessels,
        Math.min(vessels.length, 10),
        5,
      ].map(String),
```

靜態程式碼；不能單憑這段推定實際業務損害。

證據 SRC-008

合成船舶數量均為2

EV-F001-CONTEXT · /dynamic_report/vessel_context（指定欄位）

```
{
  "matched_total_vessels": 2,
  "summary_total_vessels": 2,
  "vessels_slice_len": 2
}
```

早期Attempt02，適用SRC-010的前置 / BP複核限制。

證據 SRC-009

既有單元重現與對照

EV-F001-CASE-0 · /dynamic_report/results/0（指定欄位）

```
{
  "id": "CONTROL-REAL-TOTAL-2",
  "content": "□□□□ 2 □□",
  "function_actual_output": true,
  "defect_reproduced": false
}
```

引用歷史結果，本次未執行函式；不能當原BP合規驗收。

證據 SRC-009

既有單元重現與對照

EV-F001-CASE-1 · /dynamic_report/results/1（指定欄位）

```
{
  "id": "COUNTER-WRONG-TOTAL-3",
  "content": "□□□□ 3 □□",
  "function_actual_output": false,
  "defect_reproduced": false
}
```


引用歷史結果，本次未執行函式；不能當原BP合規驗收。

證據 SRC-009

既有單元重現與對照

EV-F001-CASE-2 · /dynamic_report/results/2（指定欄位）


```
{
  "id": "COUNTER-WRONG-TOTAL-5-DEFECT",
  "content": "□□□□ 5 □□",
  "function_actual_output": true,
  "defect_reproduced": true
}
```


引用歷史結果，本次未執行函式；不能當原BP合規驗收。

證據 SRC-009

證據 SRC-007 · SRC-008 · SRC-009 · SRC-010 · SRC-016 · SRC-018 · SRC-003

GEV-C-002

待確認

上游回應缺少累積位元組上限

待驗證 | 風險等級待評 | 責任人待指定

上游MPB與Traffic回應接收未見累積位元組上限，屬待確認的資源防禦邊界。

> **分級依據**
>
> 缺上游可控性、實際超標與業務影響證據；不能把無cap直接評為已確認高風險DoS。

受影響元件

- server/providers/vessels/mpb-taiwan.js：fetchRawJson接收流程
- server/providers/traffic/taiwan-traffic.js：response.text()

成立前提

- 產品能連接固定上游來源；上游回應可能異常或受影響。
- 能否由攻擊者控制回應或連線、實際部署可用資源均待確認。

已證實事實

- MPB經chunks收集、Buffer.concat、JSON.parse解析GeoJSON；NDJSON是本機航跡儲存格式。
- 有限chunks與request error後重抓有既有觀察；Traffic輸入字元不是串流byte計量。

既有重現紀錄

以下整理歷史觀察，本次未重跑產品。

1. 查閱MPB / Traffic接收程式碼，確認現有timeout與累積流程。
2. 引用run35有限fixture觀察，並依run36勘誤將故障限定為response callback之前request error。
3. 恢復使用相同25筆fixture，只證明重抓累積解析，不推定新資料更新或無上限串流安全。

影響判讀

已觀察：已知接收端未見顯式累積body byte cap；有限資料可解析。

有條件影響：過大回應可能增加記憶體、解析成本或可用性壓力，實際影響需可控來源與資源證據。

尚未證明

- 可利用的DoS或OOM
- 無窮 / 慢速串流實際影響
- 部分body已接收後中斷的容錯

證據限制

- 固定官方來源與timeout是既有控制，不能忽略也不能當成容量上限。
- 原payload總bytes與摘要2943B / 4chunks存在未完全對齊的計量，正式風險判讀不引用總量。
- 未壓測至heap崩潰，不要求為確認架構事實而做破壞式測試。

改善建議

- 先由責任人定義合理單次回應上限、timeout與降級契約，不直接採歷史示例容量作需求。
- 在實際data接收層累計bytes並於超限終止；涵蓋錯誤傳遞、清理與stale / 恢復。
- Traffic的文字 / XML接收與解析也應獨立評估其上限。

驗收條件

- 契約上限明定後，以有界fixture驗證低於、等於、超過1byte，並量測拒絕後不持續累積。

- 分開驗證response前錯誤、有限body途中錯誤與不同新內容恢復；明記各層bytes。
- 不需OOM即可證明上限有效；部署暴露與影響證據具備後再決定候選分類。

查看 **3** 段安全證據節錄

MPB接收端累積chunks並解析JSON

EV-C002-MPB · 第 167–173 行

```
      const chunks = [];
      res.on('data', (chunk) => chunks.push(chunk));
      res.on('end', () => {
        try {
          const body = Buffer.concat(chunks).toString('utf-8');
          const json = JSON.parse(body);
          resolve(json);
```

此段未見累積byte cap；完整影響仍取決於上游可控性、timeout及部署資源。

證據 SRC-042

Traffic接收文字

EV-C002-TRAFFIC · 第 72–72 行

```
  return response.text();
```

文字接收與傳輸chunks計量是不同層級。

證據 SRC-043

有限串流 / 文字觀察

EV-C002-OBS · /results/2/payload (指定欄位)

```
{
  "mpb_real_receiving_stream_chunks_ok": true,
  "traffic_input_text_chars": 1408,
  "traffic_stream_chunks_measured": null,
  "product_byte_cap_observation": "NO_HARD_BYTE_CAP_IN_PRODUCT_UPSTREAM_CONSUMPTION
(BUFFER_CONCAT_AND_TEXT_UNBOUNDED)",
  "contract_status": "NEEDS_VALIDATION"
}
```

配合SRC-012勘誤：request error發生於response之前，恢復是相同fixture；不引用相互衝突的bytes總數。

證據 SRC-020

證據 SRC-007 · SRC-011 · SRC-020 · SRC-012 · SRC-006 · SRC-042 · SRC-043 · SRC-025

GEV-C-003

待確認

PAT父目錄鏈與部署信任邊界

待驗證 | 風險等級待評 | 責任人待指定

PAT終端檔案防護已有證據，父目錄鏈安全仍依賴部署權限與使用者信任。

> 分級依據
>
> 目前只有同UID路徑行為與指定終端防護證據，缺跨權限前提；維持待確認，不能稱已越權。

受影響元件

- server/providers/ai/ollama-advisor.js：createTokenStore

成立前提

- 可寫入或替換父目錄的主體可能影響路徑解析。
- 同UID測試不等於不同UID攻擊者具有相同權限；實際父目錄擁有者與可寫性待確認。

已證實事實

- read以O_NOFOLLOW開啟終端檔，要求一般檔案且mode為0600。
- rotate使用暫存檔與rename；既有測試支持0644及損毀JSON拒絕、旋轉恢復。
- 同UID父目錄symlink會被解析，目標0600檔案建立且canary保留。

既有重現紀錄

以下整理歷史觀察，本次未重跑產品。

1. 查閱終端open / fstat / mode檢查及父目錄建立流程。
2. 引用既有終端symlink、0644、損毀JSON與恢復觀察。
3. 引用同UID父目錄symlink結果，維持為路徑解析事實，未進行不同使用者越權測試。

影響判讀

已觀察：O_NOFOLLOW不構成完整父路徑鏈驗證；同UID父symlink可導向寫入。

有條件影響：若部署讓不受信任主體改動父目錄，可能使權杖存放位置或可用性偏離預期；需權限與競態證據。

尚未證明

- 跨UID讀取或竊取PAT
- 終端O_NOFOLLOW繞過
- 父目錄canary被覆寫

證據限制

- 未證明跨UID / 多租戶利用。
- mkdir的0700參數不代表既有父鏈皆受同樣權限保護。
- 0777沒有作為已測變體；本機同UID信任前提不是程式碼強制隔離。

改善建議

- 明定支援單使用者或共享主機的部署模型與PAT路徑擁有者。
- 依威脅模型檢查父鏈權限、symlink與身分；若需抗競態，單次lstat不能保證消除TOCTOU。
- 保留終端0600、O_NOFOLLOW、輪替撤銷與fail-closed行為。

驗收條件

- 文件記錄支援部署下的父目錄擁有者與可寫權限，對不支援配置有明確拒絕或警示契約。
- 若跨UID屬支援範圍，在有權限與授權的環境證明不受信任主體無法導向 / 讀取權杖。
- 若補強父鏈，另驗證檢查與開啟間替換情境及原PAT生命週期不退化；不自動關閉候選。

查看 **2** 段安全證據節錄

終端**O_NOFOLLOW**與**0600**檢查

EV-C003-READ · 第 17–23 行

```
let fd;
try {
  fd = fs.openSync(file, fs.constants.O_RDONLY | fs.constants.O_NOFOLLOW);
  const stat = fs.fstatSync(fd);
  if (!stat.isFile() || (stat.mode & 0o777) !== 0o600) return null;
  const value = JSON.parse(fs.readFileSync(fd, 'utf8'));
  return /^[a-f0-9]{64}$/.test(value.sha256) ? value : null;
```

只作用於終端元件；不證明父目錄鏈或跨UID隔離。

證據 SRC-041

同**UID**測試觀察

EV-C003-OBS · /results/3/payload (指定欄位)

```
{
  "terminal_rotate_0600_ok": true,
  "terminal_symlink_rejected_ok": true,
  "insecure_0644_denied_ok": true,
  "corrupt_json_denied_ok": true,
  "recovery_rotate_ok": true,
  "parent_directory_symlink_observed": true,
  "canary_content_preserved": true,
  "target_resolved_mode_0600": true,
  "contract_status": "NEEDS_VALIDATION"
}
```


0777未作已測宣稱；canary未變與0600寫入不等於跨使用者安全。

證據 SRC-020

證據 SRC-007 · SRC-011 · SRC-016 · SRC-020 · SRC-006 · SRC-041 · SRC-025

GEV-C-004

待確認

panel_request敏感路由責任與副作用隔離

待驗證 | 風險等級待評 | 責任人待指定

panel_request的工具key、標頭白名單及下游gate共同形成邊界，仍欠完整產品契約與正向對照。

> 分級依據
>
> 已有特定負向防護證據，但合法正控制及完整副作用量測不足；既不能判繞過，也不能判全路由安全。

受影響元件

- src/tools/queries/panelRequest.js
- server/providers/ai/ollama-advisor.js及Gemini敏感handler的代理鏈

成立前提

- MCP client可讀panel頁面及其中key；key本身不是人員認證秘密。
- 敏感路由的准入依代理政策與下游各自gate，需逐路由確認預期。

已證實事實

- 產品註解明示key不是access control；可讀panel的MCP client可以取得。
- 代理僅轉送accept / content-type；指定路由由proxy阻斷或由真handler拒絕。
- 既有指定負向案例中，advisor client與token rotate計數為0；Gemini provider未全面計數。

既有重現紀錄

以下整理歷史觀察，本次未重跑產品。

1. 引用真panelRequest串接真敏感handler的PassThrough測試。
2. 分開讀取proxy拒絕、advisor401、token401與Gemini403，不能用payload頂層200表示所有下游成功。
3. 保留mock tracks正控制與固定false的token verify限制，不聲稱完整合法敏感轉送已驗證。

影響判讀

已觀察：指定負向路徑被拒，部分副作用計數為零；未證明授權繞過。

有條件影響：若代理與下游的路由 / 方法契約不一致，可能使敏感操作暴露；需合法正控制及所有相關provider觀察。

尚未證明

- 全provider零副作用
- 完整人員授權或panelKey保密性
- 所有敏感路由與方法均安全

證據限制

- PassThrough不是獨立socket服務。
- token verify固定false；公開tracks正控制為mock；Gemini實際provider呼叫未全面計數。
- 合法PAT在來源呼叫存在，不表示會通過proxy白名單；不得假設Authorization被轉送。

改善建議

- 逐路由明定proxy負責拒絕與下游負責准入的契約；不把取得panelKey本身列成認證繞過。
- 設計符合實際header政策的正向 / 負向對照，必要時分開直連handler與代理路徑。
- 針對納入範圍的模型、token管理與其他副作用加入計數；key輪替 / 撤銷僅在產品契約要求時驗收。

驗收條件

- 每個核准路由 / 方法明列proxy與下游預期，並有正常對照，不能因mock永遠拒絕就判防護成立。
- 指定拒絕案例對所有納入provider及管理操作都具有可信副作用觀察。
- 驗證公開合法流程、redirect / header政策、實例與分段隔離；產品責任人判定剩餘候選，不由單例關案。

查看 **3** 段安全證據節錄

產品註解說明**panelKey**的設計用途

EV-C004-DESIGN · 第 8–14 行

```
 * It is meant for the panel. `visibility: ['app']` asks hosts to keep it
 * from the model, and every call must also carry the key in the panel's page
 * (`services.app.panelKey`), so a client that lists the tool to the model
 * without loading the panel cannot use it. The key is not access control:
 * any MCP client can read the panel's page, key included. What protects
 * sensitive routes is that those the panel never needs are refused to every
 * caller.
```

設計文字非完整安全證明；key可由讀取panel頁面的MCP client取得。

證據 SRC-044

請求**header**白名單

EV-C004-HEADERS · 第 38–38 行

```
const FORWARDED_REQUEST_HEADERS = ['accept', 'content-type'];
```

白名單不等同下游敏感路由全部已驗證。

證據 SRC-044

真**handler**指定負向案例

EV-C004-OBS · /results/0/payload (指定欄位)

```
{
  "refused_paths_blocked_at_proxy": true,
  "taiwan_ai_advisor_downstream_401_zero_model_calls": true,
  "taiwan_ai_token_downstream_401_zero_rotate_calls": true,
  "gemini_chat_downstream_403_origin_enforced": true,
  "downstream_calls_observed": 3,
  "model_client_calls_observed": 0,
  "token_rotate_calls_observed": 0,
  "contract_status": "NEEDS_VALIDATION"
}
```

PassThrough串接；Token verify固定false，tracks正控制為mock，Gemini provider未全面計數；不以頂層actual_status=200表示各路由皆200。

證據 SRC-020

證據 SRC-007 · SRC-011 · SRC-020 · SRC-003 · SRC-006 · SRC-044 · SRC-041 · SRC-025

其他觀察

OBS-001

備份檔被列入**Panel**成品清冊

保留Panel成品清冊含icons/taiwan-vessels/spec.html.bak，大小5238bytes。這支持指定建置包含備份檔，不支持真秘密外洩或已公開部署。

建議

- 確認此檔是否需要發布；不需要時在來源 / 打包流程明確排除。
- 對備份、暫存與其他非發布檔建立成品檢查，不僅依賴gitignore。

驗收條件

- 經授權的後續成品清冊不含非必要備份檔，必要公開文件有明確用途。

限制

- 本次只讀保留清冊，不重新掃描檔案內容；不能用5238bytes推定內容相同。

查看證據節錄

Panel保留清冊中的備份檔

EV-OBS-BAK · /files/699 (指定欄位)


```
{
  "relative_path": "icons/taiwan-vessels/spec.html.bak",
  "size_bytes": 5238,
  "sha256": "5c2149b8536ab0dd9b4422c793a5457b5969d77874491b70c7704e484c99bb24"
}
```


僅支持保留成品清冊列有此項；本次未重新建置或公開部署。

證據 SRC-036

證據 SRC-036 · SRC-003

OBS-002

Docker預設閘道信任需部署拓樸確認

既有來源與純函式觀察指出預設閘道可加入trusted peers；尚無實體容器網路驗證，不能推定同bridge容器已可冒充宿主。

建議

- 確認閘道所代表主體及支援部署模型，再決定是否需明確認證或不同傳輸。

驗收條件

- 如未來核准Docker測試，針對實際拓樸區分宿主 / 其他容器 / 代理主體並驗證預期准入；未測前保留PENDING。

限制

- 未啟動Docker，不新增容器逃逸或另一OS VM要求。

證據 SRC-005 · SRC-011 · SRC-006

05 / VALIDATION

防禦驗證

已驗證防護不承襲到未測路由、替身以外的服務或其他部署環境。

來源隔離與本輪控制

run-45 的三組合成對照支持：允許的 loopback 與 scratch 存取成功，未授權網路及寫入遭 EPERM，來源副本可讀而原 repo package.json 與交付 Canary 被拒讀。這證明指定 profile 與探針的隔離行為，不證明完整產品所有檔案及網路路徑均已測。

證據 SRC-026 · SRC-003

基線與驗證器

Review 45 對實際 V12 的 verify_all_sources=False / True 驗證均通過，canonical 來源集合與 1,452 份 snapshot 項目一致；四項合成 Guard 控制符合預期。此採認針對基線檢查與已測分支，不能當成驗證器所有分支、所有歷史輪次或產品本身的安全證明。

證據 SRC-003 · SRC-004

准入、權杖與代理

歷史子集包含本機准入、跨來源拒絕、PAT 建立 / 旋轉 / 撤銷、檔案權限及代理路由 / 標頭 / 實例隔離觀察。真實敏感 handler 的指定負向案例回傳 401 / 403，特定模型 client 與 token 旋轉計數為零；尚未量測的 provider、正向管理路徑或多使用者部署不可承襲此結論。

證據 SRC-005 · SRC-016 · SRC-018 · SRC-020 · SRC-021 · SRC-023 · SRC-025

取消恢復與快取

真實 runOllama 的合成串流案例，以 Async Barrier 確認進行中請求，再驗證忙碌拒絕、取消清理及後續恢復。真實快取入口搭配虛擬時鐘驗證 40 秒 TTL、失敗舊值保留與恢復。這些結果不等於真 Ollama 串流中斷、所有佇列條件或真實上游長期穩定性通過。

證據 SRC-005 · SRC-019 · SRC-020 · SRC-024 · SRC-025

有限串流與檔案儲存

既有案例支持有限 GeoJSON chunks 的累積解析、部分 request error 容忍及 NDJSON 航跡維護。run-35 的錯誤在 response callback 前發生，恢復使用相同 fixture，不能宣稱證明部分 body 中斷或不同資料增量更新；也沒有壓測到記憶體耗盡。

證據 SRC-005 · SRC-012 · SRC-018 · SRC-020 · SRC-023 · SRC-025

Panel 成品與 **Standalone** 分開

run-43 Panel 保留清冊為 722 檔、76,696,458 bytes；原審計記錄未見 sourcemap 與指定合成私密 Canary，且有陽性校準。run-45 離線 11 項檢查符合 SUPPORTED_BY_RETAINED_AUDIT，僅支持保留審計一致性，未重新掃描成品。Standalone 保留 CPU_RATE_EXCEEDED、rc=-15、0 產物，成品秘密與 sourcemap 檢查為 NOT_ASSESSED。

證據 SRC-029 · SRC-030 · SRC-031 · SRC-034 · SRC-035 · SRC-036 · SRC-038

瀏覽器失敗與治具成功並存

run-45 Supervisor 記錄 COMPLETED、OBSERVED、CLEAN、rc=0、lingering_pids=[]，表示該診斷治具完成觀測與收尾。Chrome 的 Target.setDiscoverTargets 仍回報 Target closed，元件 DOM 相依受阻。寫死的 NATIVE_OBSERVATION_FAILED 不作本輪實測，巢狀沙箱根因未證實；不以關閉 Chrome 原生沙箱取得通過。

證據 SRC-027 · SRC-028 · SRC-003

06 / COVERAGE

15 情境覆蓋與未完成範圍

覆蓋基準

覆蓋以原 GEV-01..15 為固定分母，保留每列原始身分及必要變體。歷史結果的有效子集仍可採用，但各輪控制、替身與複核限制繼續適用；目前未將任何一列宣稱為全部必要變體通過。

證據 SRC-001 · SRC-005

如何閱讀狀態

PARTIALLY VERIFIED 代表有指定層級的有效觀察，並非全情境 PASS；NEEDS VALIDATION 是候選議題仍待確認；BLOCKED 是執行或觀測前提受阻；NOT TESTED 是尚未執行。GEV-07 另含已知 OPEN 缺陷。來源設計文件中的早期 NOT TESTED 不取代後來證據，工具缺失也不抹除既有產品觀察。

證據 SRC-001 · SRC-003 · SRC-005

不可外推的範圍

目前完整 Vite 主 App / 實際 dev-preview 生命週期、受控 Chrome DOM、Docker 拓樸、真模型及真上游仍有缺口。GEV-11 的 Panel 子集不能替代 Standalone 或全產品秘密掃描；Gitleaks、Semgrep、OSV-Scanner 供給不足不能寫成零告警或已通過。

證據 SRC-003 · SRC-005 · SRC-006

不提供整案通過率

run 數量、重跑成功、PASS 變體數及 Ledger CLEAN 均不作全案完成率或安全分數。下列各情境保留「已驗證什麼、在哪一層、還缺什麼」；缺資料時保留未知，避免把局部成功或環境失敗誤寫成整體結論。

證據 SRC-001 · SRC-003 · SRC-005

15 情境證明層級矩陣

以已採認索引的主要證明層級分組，並非完整測試清冊。符號表示證據種類及限制，不表示情境通過。搜尋與狀態篩選同時套用於矩陣及下方情境說明。

- ● 指定子集有觀察，仍非全列通過
- × 該層支持已知 OPEN 缺陷
- ●! Panel子集；Standalone受阻
- △ 替身 / helper等限制性觀察
- △! 歷史觀察保留；目前瀏覽器受阻
- — 本矩陣未單列，不能解讀為未測或安全

證據層級分組・不是通過率

情境	來源	合成	介面	OS 檔案	成品	瀏覽器
GEV-01	—	—	—	●	—	—
GEV-02	—	—	●	—	—	—
GEV-03	—	●	—	●	—	—
GEV-04	—	●	●	—	—	—
GEV-05	—	—	△	—	—	—
GEV-06	—	△	△	—	—	—
GEV-07	×	×	—	—	—	—
GEV-08	●	—	—	—	—	△!
GEV-09	—	△	—	—	—	—
GEV-10	—	●	—	●	—	—
GEV-11	—	—	—	—	●!	—
GEV-12	—	●	—	—	—	—
GEV-13	—	●	—	—	—	—
GEV-14	—	●	△	—	—	—
GEV-15	—	—	—	●	—	—

證據 SRC-001 · SRC-005 · SRC-003

完整文字矩陣與情境名稱

符號是已採認證據的分組；破折號不是未測試結論。

情境與原名稱	來源	合成	介面	OS / 檔案	成品	瀏覽器
GEV-01 隔離環境與啟動副作用	— 本矩陣未單列，不能解讀為未測或安全	— 本矩陣未單列，不能解讀為未測或安全	— 本矩陣未單列，不能解讀為未測或安全	• 指定子集有觀察，仍非全列通過	— 本矩陣未單列，不能解讀為未測或安全	— 本矩陣未單列，不能解讀為未測或安全
GEV-02 AI 本機管理准入與來源邊界	— 本矩陣未單列，不能解讀為未測或安全	— 本矩陣未單列，不能解讀為未測或安全	• 指定子集有觀察，仍非全列通過	— 本矩陣未單列，不能解讀為未測或安全	— 本矩陣未單列，不能解讀為未測或安全	— 本矩陣未單列，不能解讀為未測或安全

情境與原名稱	來源	合成	介面	OS / 檔案	成品	瀏覽器
GEV-03 PAT 權限、輪替與撤銷	— 本矩陣未單列，不能解讀為未測或安全	● 指定子集有觀察，仍非全列通過	— 本矩陣未單列，不能解讀為未測或安全	● 指定子集有觀察，仍非全列通過	— 本矩陣未單列，不能解讀為未測或安全	— 本矩陣未單列，不能解讀為未測或安全
GEV-04 AI 路徑、方法與輸入邊界	— 本矩陣未單列，不能解讀為未測或安全	● 指定子集有觀察，仍非全列通過	● 指定子集有觀察，仍非全列通過	— 本矩陣未單列，不能解讀為未測或安全	— 本矩陣未單列，不能解讀為未測或安全	— 本矩陣未單列，不能解讀為未測或安全
GEV-05 MCP HTTP 與 stdio 的不同權限邊界	— 本矩陣未單列，不能解讀為未測或安全	— 本矩陣未單列，不能解讀為未測或安全	▵ 替身 / helper等限制性觀察	— 本矩陣未單列，不能解讀為未測或安全	— 本矩陣未單列，不能解讀為未測或安全	— 本矩陣未單列，不能解讀為未測或安全
GEV-06 panel_request 路由、目的地與分段隔離	— 本矩陣未單列，不能解讀為未測或安全	▵ 替身 / helper等限制性觀察	▵ 替身 / helper等限制性觀察	— 本矩陣未單列，不能解讀為未測或安全	— 本矩陣未單列，不能解讀為未測或安全	— 本矩陣未單列，不能解讀為未測或安全
GEV-07 query、selected 與上游文字的資料完整性	× 該層支持已知 OPEN 缺陷	× 該層支持已知 OPEN 缺陷	— 本矩陣未單列，不能解讀為未測或安全	— 本矩陣未單列，不能解讀為未測或安全	— 本矩陣未單列，不能解讀為未測或安全	— 本矩陣未單列，不能解讀為未測或安全
GEV-08 AI 面板、來源引用與權杖呈現	● 指定子集有觀察，仍非全列通過	— 本矩陣未單列，不能解讀為未測或安全	— 本矩陣未單列，不能解讀為未測或安全	— 本矩陣未單列，不能解讀為未測或安全	— 本矩陣未單列，不能解讀為未測或安全	▵! 歷史觀察保留；目前瀏覽器受阻
GEV-09 上游解析與回應資源界線	— 本矩陣未單列，不能解讀為未測或安全	▵ 替身 / helper等限制性觀察	— 本矩陣未單列，不能解讀為未測或安全	— 本矩陣未單列，不能解讀為未測或安全	— 本矩陣未單列，不能解讀為未測或安全	— 本矩陣未單列，不能解讀為未測或安全
GEV-10 航跡檔案、參數與保留邊界	— 本矩陣未單列，不能解讀為未測或安全	● 指定子集有觀察，仍非全列通過	— 本矩陣未單列，不能解讀為未測或安全	● 指定子集有觀察，仍非全列通過	— 本矩陣未單列，不能解讀為未測或安全	— 本矩陣未單列，不能解讀為未測或安全
GEV-11 靜態服務、成品與 bundled file 的秘密邊界	— 本矩陣未單列，不能解讀為未測或安全	— 本矩陣未單列，不能解讀為未測或安全	— 本矩陣未單列，不能解讀為未測或安全	— 本矩陣未單列，不能解讀為未測或安全	●! Panel子集；Standalone受阻	— 本矩陣未單列，不能解讀為未測或安全
GEV-12 取消、忙碌、排隊與失敗恢復	— 本矩陣未單列，不能解讀為未測或安全	● 指定子集有觀察，仍非全列通過	— 本矩陣未單列，不能解讀為未測或安全	— 本矩陣未單列，不能解讀為未測或安全	— 本矩陣未單列，不能解讀為未測或安全	— 本矩陣未單列，不能解讀為未測或安全
GEV-13 來源健康、快取及回答的時間一致性	— 本矩陣未單列，不能解讀為未測或安全	● 指定子集有觀察，仍非全列通過	— 本矩陣未單列，不能解讀為未測或安全	— 本矩陣未單列，不能解讀為未測或安全	— 本矩陣未單列，不能解讀為未測或安全	— 本矩陣未單列，不能解讀為未測或安全
GEV-14 原生、Docker、dev/preview 與分享配置差異	— 本矩陣未單列，不能解讀為未測或安全	● 指定子集有觀察，仍非全列通過	▵ 替身 / helper等限制性觀察	— 本矩陣未單列，不能解讀為未測或安全	— 本矩陣未單列，不能解讀為未測或安全	— 本矩陣未單列，不能解讀為未測或安全
GEV-15 PAT 與 panel key 檔案安全和生命週期	— 本矩陣未單列，不能解讀為未測或安全	— 本矩陣未單列，不能解讀為未測或安全	— 本矩陣未單列，不能解讀為未測或安全	● 指定子集有觀察，仍非全列通過	— 本矩陣未單列，不能解讀為未測或安全	— 本矩陣未單列，不能解讀為未測或安全

GEV-01 / RQ01

隔離環境與啟動副作用

部分驗證

已採認指定 loopback、檔案拒讀及來源副本控制；完整產品啟動、背景工作與所有副作用路徑仍未完成。

已有證據

run-40/41/42/43控制與來源隔離

尚欠與限制

完整啟動副作用 / 配置仍欠；工具缺失不可抹去控制成果

證明層級：OS_CONTROL

證據 SRC-001 · SRC-005 · SRC-026 · SRC-003

GEV-02 / RQ02

AI 本機管理准入與來源邊界

部分驗證

本機、Host、Origin、代理標頭等准入子集已有觀察；合成 peer 屬性不是實際 LAN 或反向代理拓樸驗證。

已有證據

run-15 v8-GEV-02-01..10；其他run指定HTTP觀察

尚欠與限制

Browser整合受阻，不等於本機准入函式 / HTTP未測

證明層級：HTTP_HANDLER

證據 SRC-001 · SRC-005 · SRC-016

GEV-03 / RQ03

PAT 權限、輪替與撤銷

部分驗證

旋轉、撤銷、畸形憑證及部分檔案邊界已驗；同 UID 父目錄 symlink 觀察不能證明跨 UID 隔離。

已有證據

run-15 PAT跨請求生命週期；run-34/35父鏈與檔案

尚欠與限制

跨UID / 部署信任前提與未測變體

證明層級：CROSS_REQUEST_STATE · FILESYSTEM

證據 SRC-001 · SRC-005 · SRC-016 · SRC-019 · SRC-020

GEV-04 / RQ04

AI 路徑、方法與輸入邊界

部分驗證

已有 body UTF-8 bytes、query UTF-16 code units、方法與忙碌等指定契約觀察；不能外推完整服務與所有 client。

已有證據

run-13十九middleware觀察；run-15邊界 / 429；後續代表重驗

尚欠與限制

完整服務 / Browser等缺項另列，不再要求重建已用stub

證明層級：HTTP_HANDLER · SYNTHETIC_CLIENT

證據 SRC-001 · SRC-005 · SRC-014 · SRC-016 · SRC-018

GEV-05 / RQ05

MCP HTTP 與 stdio 的不同權限邊界

部分驗證

已測 HTTP 准入 / 傳輸 helper 及 PassThrough serveStdio；完整 plugin、獨立 CLI transport 與全部工具能力仍欠驗證。

已有證據

run-23/27 v9-GEV-05-01..05：產品HTTP gate/transport、PassThrough serveStdio

尚欠與限制

完整plugin / 獨立CLI transport與工具能力分母尚欠

證明層級：HTTP_HELPER · SYNTHETIC_STDIO

證據 SRC-001 · SRC-005 · SRC-017 · SRC-018

GEV-06 / RQ06

panel_request 路由、目的地與分段隔離

部分驗證

指定路徑、標頭、實例隔離與敏感 handler 拒絕有證據；合法敏感正控制、未測路由與分段過期未完成。

已有證據

run-23/27代理路由 / headers / WeakMap；run-34/35真handler拒絕

尚欠與限制

正控制 / 未測路由與分段逾期等子條件

證明層級：HANDLER_COMPOSITION · SYNTHETIC_BACKEND

證據 SRC-001 · SRC-005 · SRC-017 · SRC-018 · SRC-019 · SRC-020

GEV-07 / RQ07

query、**selected** 與上游文字的資料完整性

含已知未修補缺陷

F-001 的錯誤船數接受已有重現，維持 OPEN；其他 query / selected / 上游文字完整性不能由此單一發現代表。

已有證據

GEV-F-001 grounding數量5重現與其他已列對照

尚欠與限制

缺陷未修；其他資料完整性分母不能由單缺陷代替

證明層級：SOURCE · UNIT_DYNAMIC

證據 SRC-001 · SRC-005 · SRC-016 · SRC-018 · SRC-007 · SRC-008 · SRC-009 · SRC-010

GEV-08 / RQ08

AI 面板、來源引用與權杖呈現

部分驗證

保留來源審查與較早指定元件 DOM 觀察，適用其控制缺口；目前 outer Seatbelt 下 Chrome 受阻，不能標整體 UI 通過。

已有證據

run-36/37來源；run-38/39指定DOM觀察但控制有限

尚欠與限制

目前受控Browser / UI未測，不移植舊DOM為合規PASS

證明層級：SOURCE · HISTORICAL_BROWSER_OBSERVATION

證據 SRC-001 · SRC-005 · SRC-027 · SRC-028 · SRC-003

GEV-09 / RQ09

上游解析與回應資源界線

部分驗證

已有 parser、有限 MPB chunks 及回應前 request error 觀察；無 body cap 的利用影響、中途 body 異常與其他資源變體仍未確認。

已有證據

run-23/27 parser/ollama；run-35真MPB有限chunks與request error

尚欠與限制

無body cap的風險判讀 / 中途body失效等未測

證明層級：FINITE_STREAM_STUB · PARSER

證據 SRC-001 · SRC-005 · SRC-017 · SRC-018 · SRC-020 · SRC-012

GEV-10 / RQ10

航跡檔案、參數與保留邊界

部分驗證

檔案權限、部分參數、NDJSON 容錯及保留清理已有觀察；fake clock 不證明七天實際吞吐或磁碟容量安全。

已有證據

run-23/27 v9-GEV-10-01..03：store / fake-clock過期 / NDJSON / proxy

尚欠與限制

未測檔案邊界與容量，不要求168小時真流量作全部前提

證明層級：FILESYSTEM · VIRTUAL_CLOCK

證據 SRC-001 · SRC-005 · SRC-017 · SRC-018

GEV-11 / RQ11

靜態服務、成品與 **bundled file** 的秘密邊界

部分驗證

Panel 保留建置子集有證據，離線重評支持原審計；Standalone CPU 超限無成品，完整公開服務及秘密邊界仍未完成。

已有證據

run-42 inline成品；run-43 panel工廠 / 前導步驟成品

尚欠與限制

Standalone CPU受阻、完整秘密 / 公開服務 / 發布對照仍欠

證明層級：BUILD_SUBSET · RETAINED_AUDIT

證據 SRC-001 · SRC-005 · SRC-029 · SRC-038 · SRC-034 · SRC-030

GEV-12 / RQ12

取消、忙碌、排隊與失敗恢復

部分驗證

Async Barrier 確認進行中請求後取消、finally 與忙碌鎖恢復；其他排隊、真計時及端到端取消仍欠驗證。

已有證據

run-15忙碌 / 恢復；run-34/35真runOllama + barrier取消 / finally

尚欠與限制

未測queue / 其他timeout / 端到端層級，不稱只做靜態

證明層級：UNIT_DYNAMIC · ASYNC_BARRIER

證據 SRC-001 · SRC-005 · SRC-016 · SRC-019 · SRC-020

GEV-13 / RQ13

來源健康、快取及回答的時間一致性

部分驗證

真實快取入口與虛擬時鐘支持 TTL、stale 及恢復行為；UI、回答與來源的時間一致性尚有缺項。

已有證據

run-34/35真getTaiwanVessels快取40s / stale / 恢復

尚欠與限制

UI / 回答時間一致性及未測變體

證明層級：VIRTUAL_CLOCK · UPSTREAM_STUB

證據 SRC-001 · SRC-005 · SRC-019 · SRC-020

GEV-14 / RQ14

原生、**Docker**、**dev/preview** 與分享配置差異

部分驗證

保留 docker-start 純函式及指定 HTTP 管線結果；不宣稱實體 Docker 網路、完整 dev-preview 或其他 launcher 均已通過。

已有證據

run-37 docker-start十二純函式 / collector；run-41/42 HTTP子集

尚欠與限制

Docker / 真dev-preview完整生命週期與配置差異

證明層級：PURE_FUNCTION · MIDDLEWARE_COLLECTOR

證據 SRC-001 · SRC-005

GEV-15 / RQ15

PAT 與 **panel key** 檔案安全和生命週期

部分驗證

已有兩個 Node 子行程 key 一致性、部分權限與 PAT 觀察；崩潰、修復鎖競態與部署契約仍未完成。

已有證據

run-23同程序key；run-27兩Node子程序key一致 / 0600；PAT觀察

尚欠與限制

崩潰 / 鎖競態分支與部署契約尚欠，不當跨程序全未測

證明層級：MULTIPROCESS · FILESYSTEM

證據 SRC-001 · SRC-005 · SRC-017 · SRC-018

07 / HANDOVER

改善與交接

建議處理順序

先就已確認F-001取得修補與回歸決策，同時指定候選責任人並確認負載、UID與代理契約；其次補齊可核實工具供給及尚欠驗收前提。這是報告建議順序，不是已核准時程、嚴重度分級或風險接受。

證據 SRC-007 · SRC-003 · SRC-006

保持現有決策

2CPU原生macOS選項A已定。Standalone超限、Chrome受阻與Docker未測保留原狀，不以重新要求3CPU、關閉沙箱或建VM解除。只有新方案、新證據或相應授權才安排不同目的的後續工作。

證據 SRC-003 · SRC-006

關案與驗收分開

修補候選、改文件、供給工具與安全驗收是不同工作。F-001須有修補、對照回歸與來源 / 成品一致性複核；候選須依已定契約與影響證據分類；部分工具或局部PASS都不構成整案放行。

證據 SRC-001 · SRC-003 · SRC-006 · SRC-007

改善工作的建議順序

這是報告建議的處理順序，不是已核准時程、CVSS排序或風險接受。各階段可並行準備；後續驗收須先具備對應輸入。



本圖保持靜態；箭頭是建議先後，不是新增授權或固定排程。

證據 SRC-003 · SRC-006 · SRC-007

節點文字對照與證據

01 先釐清責任與修補決策・建議先處理，不代表已授權

先處理已確認問題的修補決策，同時釐清上游容量、UID信任與代理責任。

前往相關發現 / 證據節錄

證據 SRC-007 · SRC-006

02 補齊所需輸入與新方案・原生 **macOS** / **2 CPU** 維持

工具供給可與契約釐清並行；Standalone、Chrome與Docker不因交接而自動獲准新測試。

前往相關發現 / 證據節錄

證據 SRC-006 · SRC-003

03 依契約回歸與獨立複核・完成條件，不是目前已完成

取得修補或必要輸入後，依明定驗收條件驗證；局部結果不直接換成全案放行。

前往相關發現 / 證據節錄

證據 SRC-001 · SRC-003 · SRC-007

ACT-01

F-001修補與回歸決策

待決策

所需輸入

有權維護者明確授權及修補方案，不要求特定格式授權書。

完成條件

修補後依F-001驗收條件完成既有重現、正常及邊界對照，複核後才可關閉。

責任人與期限待定；本項為交接建議，尚未核准執行。

證據 SRC-007 · SRC-006

ACT-02

候選負載 / 部署 / 代理契約

待定契約

所需輸入

指定責任人並明定上游容量、UID信任、代理路由與副作用責任。

完成條件

每個候選依自己的契約、正常對照與影響證據判定，不重做相同負向測試。

責任人與期限待定；本項為交接建議，尚未核准執行。

證據 SRC-011 · SRC-006

ACT-03

必要工具離線供給

缺必要工具

所需輸入

可追溯固定版本Semgrep、Gitleaks、OSV與其所需規則 / 資料庫；未知hash保持null。

完成條件

依原BP校準並完成核准範圍掃描；保存版本、資料日期、範圍與告警判讀，未掃描不作零發現。

責任人與期限待定；本項為交接建議，尚未核准執行。

證據 SRC-006 · SRC-013 · SRC-040

ACT-04

Standalone保留受阻

受阻

所需輸入

有可審查的新原預算優化方案時再評估，當前不重提3CPU。

完成條件

有成品才進行對應秘密 / sourcemap與內容驗收；0產物維持NOT_ASSESSED。

責任人與期限待定；本項為交接建議，尚未核准執行。

證據 SRC-003 · SRC-029 · SRC-030

ACT-05

Chrome與相依DOM

受阻

所需輸入

新的macOS相容性假說及可驗證證據，保留原生沙箱。

完成條件

真瀏覽器與實際元件觀察成立才評定該層；jsdom不能替代瀏覽器安全驗收。

責任人與期限待定；本項為交接建議，尚未核准執行。

證據 SRC-003 · SRC-028 · SRC-006

ACT-06

Docker部署範圍

未測試

所需輸入

如未來提供受控容器環境與相應範圍授權，再依原矩陣設計。

完成條件

取得實體配置、網路及准入證據前保留PENDING；不追加容器逃逸要求。

責任人與期限待定；本項為交接建議，尚未核准執行。

證據 SRC-001 · SRC-006

ACT-07

發布衛生確認

待責任人決定

所需輸入

確認備份檔發布用途與後續成品檢查規則。

完成條件

清冊與內容符合核定發布用途，不能由檔案存在直接推論秘密外洩。

責任人與期限待定；本項為交接建議，尚未核准執行。

證據 SRC-036

08 / EVIDENCE

證據附錄

本頁內嵌報告資料及必要安全節錄。完整來源檔未包含在單一 HTML；以下相對連結需保留原資料夾結構才能開啟。

報告介面驗證範圍

報告內容整理、來源核對、合成互動及靜態圖像檢查已完成。瀏覽器管道不可用，桌機 / 手機實際排版、原生鍵盤操作、真瀏覽器CSP與列印仍未驗證；A4輸出僅以獨立排版工具檢視，不代替瀏覽器驗收。

來源 / 節錄與原**15**情境

PASS · 45份來源、644處來源引用、14段節錄及15情境核對。

篩選、證據、深連結與列印事件

SYNTHETIC_DOM_PASS · 使用既有happy-dom檢查，不代表真瀏覽器。

SVG圖像

STATIC_REVIEWED · 既有rsvg-convert輸出；列印引擎中已檢查並修正SVG樣式。

A4列印預覽

PRINT_ENGINE_REVIEWED · WeasyPrint獨立排版預覽；不等於Chrome列印。

桌機 / **390px**手機實際排版

NOT_VERIFIED_BROWSER_UNAVAILABLE · Browser列舉為空；既有Chrome最小啟動Target closed，不重試或關沙箱。

原生鍵盤 / **CSP** / **OS**減少動態

NOT_VERIFIED_BROWSER_UNAVAILABLE · 只完成語意結構、焦點宣告及減少動態的合成狀態檢查。

附錄判讀原則

來源索引與術語供複核使用；單檔內只有經選取的安全節錄，完整原始證據需要原資料夾結構。歷史檔案中已撤回的表述，以本報告採認與勘誤欄為準。

證據 SRC-003 · SRC-005 · SRC-006

術語與判讀規則

CONFIRMED / OPEN

缺陷已有支持證據，但仍未修補 / 關閉；不代表已完成風險分級。

證據 SRC-007 · SRC-003

NEEDS VALIDATION

候選問題的暴露、契約或影響仍欠證據；既不是已確認漏洞，也不是安全通過。

證據 SRC-007 · SRC-006

PARTIALLY VERIFIED

有指定層級的子集觀察；原情境尚有必要變體未完成。

證據 SRC-001 · SRC-005

BLOCKED / NOT TESTED

前提或能力受阻 / 尚未執行；不能改成PASS或N/A。

證據 SRC-001 · SRC-003

EXECUTED / INHERITED / OFFLINE

分別為本輪實際執行、沿用歷史觀察、重新判讀保留資料；離線重評不等於重掃或重建。

證據 SRC-003 · SRC-029

SHA-256 / 簽章

本報告hash用於檔案完整性對照，不是具名簽署或所有歷史行為的證明。

證據 SRC-006

反應式控制 / 硬配額

本案NATIVE-01依取樣與超限停止控制，有遺漏與停止延遲；不能稱核心硬配額或固定最壞上界。

證據 SRC-002

風險等級 / 處理順序

嚴重度需暴露與影響證據；報告建議先做的工作，不等於CVSS排名、核准時程或風險接受。

證據 SRC-007 · SRC-006

證明層級英文代碼對照

`OS_CONTROL`

指定作業系統控制探針；不等於完整產品行為。

`HTTP_HANDLER`

指定產品處理常式 / HTTP契約；依各輪實際傳輸與替身判讀。

`CROSS_REQUEST_STATE`

連續請求間的狀態變化；不等於所有部署生命週期。

`FILESYSTEM`

測試目錄中的檔案行為；保留UID、父鏈與平台限制。

`SYNTHETIC_CLIENT`

模型client由合成替身提供，不是真模型。

`HTTP_HELPER`

指定HTTP helper或局部管線，不是完整服務。

`SYNTHETIC_STDIO`

PassThrough等合成stdio管線，不是獨立CLI完整驗收。

`HANDLER_COMPOSITION`

真實處理常式串接，可能使用合成req/res。

`SYNTHETIC_BACKEND`

後端 / 公開正控制為替身，不可外推真provider。

`SOURCE`

靜態程式碼或來源追溯，不證明部署時生效。

`UNIT_DYNAMIC`

指定單元入口的動態觀察，適用該輪控制限制。

`HISTORICAL_BROWSER_OBSERVATION`

保留較早指定元件觀察及控制限制；不是目前受控瀏覽器通過。

FINITE_STREAM_STUB

固定有界chunks替身；不證明無限串流或實際上游。

PARSER

指定資料解析行為，不等於傳輸與整體資源防護。

VIRTUAL_CLOCK

注入虛擬時間，不代表相同長度真流量。

BUILD_SUBSET

特定配置 / 目標的成品子集，不是所有建置目標。

RETAINED_AUDIT

依保留清冊與審計判讀，不是重新掃描原成品。

ASYNC_BARRIER

以同步屏障確認進行中操作後再測取消等行為。

UPSTREAM_STUB

上游使用合成替身，不連真外部服務。

PURE_FUNCTION

純函式算法驗證，不啟動其代表的部署環境。

MIDDLEWARE_COLLECTOR

合成server收集器或局部中介管線，不等於全Vite生命週期。

MULTIPROCESS

指定多行程對照，不等於長期壓力或全部競態。

證據如何沿用與校正

依相關事件的日期與採認關係整理，不按run數量計算覆蓋。來源執行與目前引用方式分開記錄；箭頭僅表示時間 / 判讀先後。 日期以Asia/Taipei表示；run ID不是執行日期證明。缺時戳時僅列輪次，不推造時間。

11/07 | 2026

F-001 取得單元重現

HISTORICAL_EXECUTION

實際2艘，錯誤5艘仍被接受。

11/08 | 2026

失敗與修正後結果並存

HISTORICAL_EXECUTION

run-14失敗，run-15另建新attempt。

run-27 → 35 | 輪次順序

契約測試逐步補齊

HISTORICAL_EXECUTION

MCP／代理、取消／快取等指定子集。

11/09 | 原始觀察 → 沿用

Standalone 保留受阻觀察

INHERITED_OBSERVATION

原始run-43：CPU_RATE_EXCEEDED。

11/09 | 原始成品 → 離線重評

Panel 成品審計離線重評

OFFLINE_REEVALUATION

run-43的722檔清冊，離線11項符合。

11/09 | 07:47 臺灣時間

run-45 探針與診斷實際執行

EXECUTED

Task1隔離對照；Task2治具正常收尾。

11/09 | 文件日期

Review45 採認與文件勘誤

REVIEW_AND_ERRATUM

Guard／出處採認，撤回寫死舊觀測值。

證據 SRC-003 · SRC-005 · SRC-029 · SRC-006

時間軸文字對照

11/07 | 2026 · F-001 取得單元重現

HISTORICAL_EXECUTION

實際2艘，錯誤5艘仍被接受。

早期前置 / BP有缺口；不回填為合規驗收。

證據 SRC-007 · SRC-009 · SRC-010

11/08 | 2026 · 失敗與修正後結果並存

HISTORICAL_EXECUTION

run-14失敗，run-15另建新attempt。

保留失敗；後來PASS不覆寫原證據。

證據 SRC-015 · SRC-016 · SRC-021

run-27 → 35 | 輪次順序 · 契約測試逐步補齊

HISTORICAL_EXECUTION

MCP / 代理、取消 / 快取等指定子集。

run-27到35適用各輪替身與複核限制。

證據 SRC-018 · SRC-020 · SRC-023 · SRC-025

11/09 | 原始觀察 → 沿用 · Standalone 保留受阻觀察

沿用歷史觀察

原始run-43：CPU_RATE_EXCEEDED。

run-45沒有重建；0成品為NOT_ASSESSED。

證據 SRC-029 · SRC-030 · SRC-031

11/09 | 原始成品 → 離線重評 · Panel 成品審計離線重評

離線重評

run-43的722檔清冊，離線11項符合。

SUPPORTED_BY_RETAINED_AUDIT，不是重掃。

證據 SRC-029 · SRC-034 · SRC-038

11/09 | 07:47 臺灣時間 · run-45 探針與診斷實際執行

實際執行

Task1隔離對照；Task2治具正常收尾。

Chrome仍Target closed，不能稱DOM通過。

證據 SRC-026 · SRC-027 · SRC-028 · SRC-003

11/09 | 文件日期 · Review45 採認與文件勘誤

REVIEW_AND_ERRATUM

Guard / 出處採認，撤回寫死舊觀測值。

保留原15情境、2CPU與全案未放行。

證據 SRC-003 · SRC-004 · SRC-006

執行與沿用分類

TASK-1 實際執行

原始執行來源：run-agy-20261108-45

證據 SRC-026 · SRC-003

TASK-2 實際執行

原始執行來源：run-agy-20261108-45

證據 SRC-027 · SRC-028 · SRC-003

TASK-3 沿用歷史觀察

原始執行來源：run-agy-20261108-43

證據 SRC-029 · SRC-030 · SRC-031

TASK-4 離線重評

原始執行來源：run-agy-20261108-43

證據 SRC-029 · SRC-038 · SRC-034 · SRC-035

採認與勘誤判讀

F001誤名

F001僅指grounding固定允許5；撤回TLS / Host / KeySetup誤名。

證據 SRC-007 · SRC-008 · SRC-003

原情境與舊**NOT TESTED**

原矩陣只決定身分與分母，當前狀態依最新採認索引，保留歷史局部證據。

證據 SRC-001 · SRC-005 · SRC-006

Chrome觀測衝突

本輪supervise_result與日誌OBSERVED/CLEAN/rc0；寫死NATIVE_OBSERVATION_FAILED不採。Chrome Target closed仍受阻，原因未證實。

證據 SRC-027 · SRC-028 · SRC-003

建置出處

Standalone沿用run43，Panel為離線重評，不當成run45新建置。

證據 SRC-029 · SRC-038

C002中斷與恢復

run35為回應前request error、同fixture重抓，不宣稱body途中中斷或新內容更新。

證據 SRC-012 · SRC-020

驗收門檻與預算

維持2CPU；不要求3CPU/3GiB、特定授權書、補充工具或容器逃逸測試。

證據 SRC-003 · SRC-006 · SRC-039

工具完整性

未知工具hash為null，SHA256不是簽章；缺供給不冒充掃描通過。

證據 SRC-013 · SRC-006

重跑 / 失敗保留

run14失敗保留，run15成功不覆寫；重跑數不增加覆蓋或漏洞數。

證據 SRC-015 · SRC-016 · SRC-005

尚未確認的問題

風險分級與業務影響

尚無充分實際暴露與業務用途資料，不填CVSS或實際損害。

證據 SRC-007

部署及產品契約

候選責任人、上游負載上限、UID信任與代理契約待定。

證據 SRC-011 · SRC-006

瀏覽器受阻根因

Target closed不能證明核心巢狀沙箱錯誤。

證據 SRC-003 · SRC-028

C002歷史傳輸byte總量

run35 payload mpb_stream_bytes_emitted=7342，而後續勘誤列2943B / 4chunks；總量未完全對齊，不作容量或更新內容證明。

證據 SRC-020 · SRC-012 · SRC-025

評估限制

風險與業務影響未知

實際部署暴露與決策用途不足，不捏造CVSS、具名風險接受或實際損失。

證據 SRC-007 · SRC-006

反應式資源控制

監測有取樣遺漏與停止前超額，不是核心硬配額，沒有固定最壞停止上界。

證據 SRC-002

真服務與環境未測

真模型 / 上游、完整Vite生命週期、目前受控DOM與實體Docker仍有未完成項。

證據 SRC-005 · SRC-006

工具供給未備妥

無完整SAST / SCA / 秘密工具輸出，不能將人工清冊或陰性關鍵字掃描代替工具驗收。

證據 SRC-006 · SRC-013

歷史證據受各輪限制

正常fixture、合成peer、PassThrough與虛擬時鐘不能外推實際拓樸 / 長期容量；沿用結果不是新執行。

證據 SRC-003 · SRC-005 · SRC-012 · SRC-029

證據一致性殘餘

C002歷史bytes總量不完全對齊，排除作為容量證明；以程式碼、限定字段及勘誤支持候選判讀。

證據 SRC-012 · SRC-020 · SRC-025

來源索引

SHA-256 是完整性雜湊，不是數位簽章。索引記錄報告整理時讀取的版本；歷史檔案中的其他主張仍須套用本報告勘誤與複核限制。

SRC-001

原15情境名稱、要求與分母；設計時NOT TESTED不作當前狀態

security-assessment/test-matrix.md

完整性與定位

第 24 行：## 3. 情境總表

大小：30,059 bytes

SHA-256

2a3ff14e3711f8041655e3a918608713b9281fd46df678ff98cd5f1111dd5073

SRC-002

既有ROE與NATIVE-01，報告不新增授權

security-assessment/rules-of-engagement.md

完整性與定位

完整來源索引；未內嵌全文

大小：23,822 bytes

SHA-256

4dd5b723526bc135812407fa18e2785d243deabe363aa78ecf9a62ea321c58fd

SRC-003

採認Guard及出處；Chrome觀測值勘誤

security-assessment/execution/review-agy-20261108-45/review.md

完整性與定位

第 17 行：## RV45-01

大小：4,375 bytes

SHA-256

`3ee11a32a97b0c149d47e4c915d08a59600a7d02e06c5e1d1208018b38fb21f7`

SRC-004

實際V12雙模式與合成Guard控制；未執行產品

security-assessment/execution/review-agy-20261108-45/verification.json

完整性與定位

完整來源索引；未內嵌全文

大小：2,853 bytes

SHA-256

`343d5c67a2596f6f744877da463ddbacc26b6ece0d85d2bd0f73141f6bbce7c4`

SRC-005

各歷史子集保留原控制限制，不升級情境PASS

security-assessment/execution/run-agy-20261108-45/corrected-scenario-index.md

完整性與定位

完整來源索引；未內嵌全文

大小：2,863 bytes

SHA-256

`378d5fb5842bf6b088b5e5182e68d5741bc4174343273a060b6b4f02a39a81b6`

SRC-006

Review45後已校正的未完成交接與原15情境

security-assessment/execution/outstanding-requirements-and-inputs.md

完整性與定位

完整來源索引；未內嵌全文

大小：13,099 bytes

SHA-256

`848fdc8e5124505812168da48d7122b755e85445e7e0b33b01e230c8a15afdea`

SRC-007

F001權威身分及候選；早期證據限制仍適用

security-assessment/execution/findings.md

完整性與定位

第 5 行：## GEV-F-001

大小：5,978 bytes

SHA-256

`77e15302b9c2a0b25ee69e478cfa8d3e34e91fc5475f470a1dba7988e5708efe`

SRC-008

realCounts.艘允許集合含常數5，僅唯讀取hash與定位

1151104_gods-eye-view/repo/server/providers/ai/ollama-client.js

完整性與定位

第 76 行： const realCounts =

大小：6,321 bytes

SHA-256

`5e88663345a3265d877d9839cd7a539e6d291328c41577f13be1b02a9b7e5250`

SRC-009

早期單元重現；不能當原BP合規驗收

security-assessment/execution/run-agy-20261107-02/gev-f001-v2-evidence.json

完整性與定位

完整來源索引；未內嵌全文

大小：4,535 bytes

SHA-256

`4ac212b23d9e1c7073d47e9b493679d4fad8eda2cb272f5cde1e9793d4728b17`

SRC-010

早期重現的前置 / CPU預算限制

security-assessment/execution/review-agy-20261107-02/review.md

完整性與定位

完整來源索引；未內嵌全文

大小：6,550 bytes

SHA-256

`0373b0858f48b87946337fd3b3dd5990cd4d91934fce5d9bbcc1ebe4e49b1d7d`

SRC-011

候選事實與部署前提，不代表確認漏洞

security-assessment/execution/run-agy-20261108-45/candidate-phase-decisions.md

完整性與定位

完整來源索引；未內嵌全文

大小：3,629 bytes

SHA-256

`239877a8cf528e396b2043df319acfc5e7c267dc7f0e532e560a7401d40ee41f`

SRC-012

C002為response前request error、同fixture恢復；tamper測試本質勘誤

security-assessment/execution/run-agy-20261108-36/errata-run-35.md

完整性與定位

完整來源索引；未內嵌全文

大小：2,899 bytes

SHA-256

`684bc25d234e30d522e4fa44cdfba2891873fb1ac34011a78fe4ac2ec5df716f`

SRC-013

恢復歷史覆蓋與工具假hash撤回

security-assessment/execution/review-agy-20261108-43/review.md

完整性與定位

完整來源索引；未內嵌全文

大小：6,384 bytes

SHA-256

`14299520bc188107ae131f265c7198b006afb37d4261d399db1a51770cac40ac`

SRC-014

早期19個advisor中間件觀察，適用其歷史控制限制

security-assessment/execution/run-agy-20261108-13/product-subset-results.json

完整性與定位

完整來源索引；未內嵌全文

大小：130,599 bytes

SHA-256

`c9fc02782048b96ba8820fdb8cfe95ae8192010469646cdeffd6b4b2fb16a912`

SRC-015

保留失敗attempt，不以後續成功覆寫

security-assessment/execution/run-agy-20261108-14/product-subset-results.json

完整性與定位

完整來源索引；未內嵌全文

大小：133,372 bytes

SHA-256

`5f65cacab156ecdddd94300017cfc3dec7bb4b8861074211deaa8ca447c063ee`

SRC-016

准入 / PAT生命週期 / AI邊界子集

security-assessment/execution/run-agy-20261108-15/product-subset-results.json

完整性與定位

完整來源索引；未內嵌全文

大小：133,361 bytes

SHA-256

`cfcc1dc4410fb929ec1aee8e99b5d0add342feb605108d0aa414f14f5a01586d`

SRC-017

MCP / Panel / 解析 / 儲存 / key歷史子集

security-assessment/execution/run-agy-20261108-23/product-subset-results.json

完整性與定位

完整來源索引；未內嵌全文

大小：134,992 bytes

SHA-256

`cc68cb19079568215eb60564e4cb379491c77fc49a6ed0dfc175200292bd41be`

SRC-018

產品契約與跨行程key歷史子集

security-assessment/execution/run-agy-20261108-27/product-subset-results.json

完整性與定位

完整來源索引；未內嵌全文

大小：355,291 bytes

SHA-256

`5e656fe2142d90e54f2825aaeb867f095c4058299413946a593bd29c591ac5cd`

SRC-019

候選與取消 / 快取進階子集

security-assessment/execution/run-agy-20261108-34/product-subset-results.json

完整性與定位

完整來源索引；未內嵌全文

大小：7,434 bytes

SHA-256

`a00cb843a2d4c2dcd568351c62f90123961bba9b0d0c700e1bd4e7597da6f677`

SRC-020

五項契約子集，部分宣稱由run36勘誤限定

security-assessment/execution/run-agy-20261108-35/product-subset-results.json

完整性與定位

完整來源索引；未內嵌全文

大小：7,749 bytes

SHA-256

`ff8fd7a7cccf181231a016f071bc8ad0e206cf4895fe30cb04be9fea3dcf6587`

SRC-021

對應輪次的採認範圍及替身 / 控制限制

security-assessment/execution/review-agy-20261108-15/review.md

完整性與定位

完整來源索引；未內嵌全文

大小：4,719 bytes

SHA-256

`41f99519977ac2427946924e8e3af98700a5c99db6ff83366fdc5cb69ae84071`

SRC-022

對應輪次的採認範圍及替身 / 控制限制

security-assessment/execution/review-agy-20261108-23/review.md

完整性與定位

完整來源索引；未內嵌全文

大小：4,798 bytes

SHA-256

`00deb896ed824525f09344e21df73205d81979b92048931e24d0186c7ba430dc`

SRC-023

對應輪次的採認範圍及替身 / 控制限制

security-assessment/execution/review-agy-20261108-27/review.md

完整性與定位

完整來源索引；未內嵌全文

大小：5,197 bytes

SHA-256

`da2f2f358c94c2fb4194ef616222907d13af74cda12b7a906ef069ada2ec00c2`

SRC-024

對應輪次的採認範圍及替身 / 控制限制

security-assessment/execution/review-agy-20261108-34/review.md

完整性與定位

完整來源索引；未內嵌全文

大小：4,970 bytes

SHA-256

`a25e912e418a3a7251421cb1884c4ba8dff05b3805169309d6ae3bc45bd77ac7`

SRC-025

對應輪次的採認範圍及替身 / 控制限制

security-assessment/execution/review-agy-20261108-35/review.md

完整性與定位

完整來源索引；未內嵌全文

大小：4,978 bytes

SHA-256

`9f6f744281927f117fb173bff2c5b8bda2443f13fa33c50011a3eed2ac0e914a`

SRC-026

三組合成控制結果；Task1實際執行

security-assessment/execution/run-agy-20261108-45/controlled-replica-access-audit.json

完整性與定位

完整來源索引；未內嵌全文

大小：3,303 bytes

SHA-256

`97ade20533e0cf4f7fd52a16b8da7020e8f61ef3aef5a3a8e1ebc35e65aebf80`

SRC-027

以supervise_result為本輪值，diagnostic_detail寫死值已撤回

security-assessment/execution/run-agy-20261108-45/browser-capability-smoke.json

完整性與定位

完整來源索引；未內嵌全文

大小：1,442 bytes

SHA-256

`0fb546fc0c3de27f8f4ba3aef7e3fabbb5da2a9f74db97386bec0c8773606a45`

SRC-028

OBSERVED/CLEAN與Chrome Target closed分層證據

security-assessment/execution/run-agy-20261108-45/evidence/redacted/TASK-B-BROWSER-SMOKE/evidence.redacted.log

完整性與定位

第 11 行：=== OBSERVATION_STATUS ===

大小：3,537 bytes

SHA-256

`1b654a06474ba4d6b4d3dc5cc478cd58716040088f378b7e73d7089fae4529a5`

SRC-029

四份run43到run45來源與派生hash

security-assessment/execution/run-agy-20261108-45/historical-build-provenance.json

完整性與定位

完整來源索引；未內嵌全文

大小：2,619 bytes

SHA-256

`142eca587506c1ec07353ea7909aaa9dd8583282a4952c2799ecf11f499719b0`

SRC-030

Standalone原預算受阻 / Panel保留成品；本輪未重建

security-assessment/execution/run-agy-20261108-43/standalone-build-audit.json

完整性與定位

完整來源索引；未內嵌全文

大小：937 bytes

SHA-256

`1ee593bd339c02874de34d9c9fa2e026be879276395500d92064f295eca7a95d`

SRC-031

Standalone原預算受阻 / Panel保留成品；本輪未重建

security-assessment/execution/run-agy-20261108-45/standalone-build-audit.json

完整性與定位

完整來源索引；未內嵌全文

大小：1,608 bytes

SHA-256

`f9596c120533cbf844df9ba569a1db829810beea928ff46b71cf69088989ce20`

SRC-032

Standalone原預算受阻 / Panel保留成品；本輪未重建

security-assessment/execution/run-agy-20261108-43/standalone-artifact-inventory.json

完整性與定位

完整來源索引；未內嵌全文

大小：446 bytes

SHA-256

`84bf0be36693aa28b68fa2894ca729222169c8001d2a2316a4d08623f40290a9`

SRC-033

Standalone原預算受阻 / Panel保留成品；本輪未重建

security-assessment/execution/run-agy-20261108-45/standalone-artifact-inventory.json

完整性與定位

完整來源索引；未內嵌全文

大小：803 bytes

SHA-256

`3c2cfe06ee2d98427fa9ec4661338c5d8a499cad215594aed21922adf4e9cbed`

SRC-034

Standalone原預算受阻 / Panel保留成品；本輪未重建

security-assessment/execution/run-agy-20261108-43/panel-build-audit.json

完整性與定位

完整來源索引；未內嵌全文

大小：1,610 bytes

SHA-256

`8011e5a7639e861d94cd1eb3f8bfd0e195a1caacd547d9c8d90b8cf6cec42b7f`

SRC-035

Standalone原預算受阻 / Panel保留成品；本輪未重建

security-assessment/execution/run-agy-20261108-45/panel-build-audit.json

完整性與定位

完整來源索引；未內嵌全文

大小：1,974 bytes

SHA-256

`b3edb2a44fd65d08834f31639c8c7769107f58f392ba6524d45b53a2869d9d3e`

SRC-036

Standalone原預算受阻 / Panel保留成品；本輪未重建

security-assessment/execution/run-agy-20261108-43/panel-artifact-inventory.json

完整性與定位

完整來源索引；未內嵌全文

大小：134,121 bytes

SHA-256

`61d8061d746737cc736f684c96dc8bb1f99032f2413b19f9f43a71c8060abb9f`

SRC-037

Standalone原預算受阻 / Panel保留成品；本輪未重建

security-assessment/execution/run-agy-20261108-45/panel-artifact-inventory.json

完整性與定位

完整來源索引；未內嵌全文

大小：134,414 bytes

SHA-256

`f4a8bd33272209796afff5d8dd1d78f487ca3d7bbf3f96f35800465568d58c91`

SRC-038

離線11項檢查，不是重掃成品

security-assessment/execution/run-agy-20261108-45/panel-evaluation-result.json

完整性與定位

完整來源索引；未內嵌全文

大小：863 bytes

SHA-256

`584af689ef0f73dafa512f87f6f916e0cd579990a44d7809ff5f222f5e5cda9d`

SRC-039

每task原BP預算；不把3CPU當待決要求

security-assessment/execution/run-agy-20261108-45/task-budgets-and-limits.json

完整性與定位

完整來源索引；未內嵌全文

大小：2,297 bytes

SHA-256

`8b63ab1f7aa03bb552434024f50d036f6102d660110bd279a07b8bc44d9f763c`

SRC-040

缺工具 / 規則DB；未知hash維持null，補充工具不變必要門檻

security-assessment/execution/run-agy-20261108-45/tool-offline-supply.json

完整性與定位

完整來源索引；未內嵌全文

大小：2,791 bytes

SHA-256

`c5fe2037f41610cb628d9727e68fc174085ddda4c7373d6ed01d319415a6449e`

SRC-041

PAT終端讀取、權限與旋轉流程；僅節錄程式碼

1151104_gods-eye-view/repo/server/providers/ai/ollama-advisor.js

完整性與定位

第 13 行：export function createTokenStore(

大小：10,772 bytes

SHA-256

`601d4508b1ef2544ac95afee89e968cab1d38f3f49621b153759a8e567f9ea18`

SRC-042

上游chunks累積與JSON解析；不連上游

1151104_gods-eye-view/repo/server/providers/vessels/mpb-taiwan.js

完整性與定位

第 167 行： const chunks = [];

大小：10,211 bytes

SHA-256

b0e5597153cce4160163f374fc9fccdf96a28dca3fff4deca914a50beff51d08

SRC-043

traffic文字接收；僅靜態程式碼

1151104_gods-eye-view/repo/server/providers/traffic/taiwan-traffic.js

完整性與定位

第 72 行： return response.text();

大小：16,788 bytes

SHA-256

2f517c36ea8283ab63b791521dcf4958d697ad766a3c80c19868fb56518ed19a

SRC-044

panelKey設計不是人員認證；拒絕路徑與header白名單

1151104_gods-eye-view/repo/src/tools/queries/panelRequest.js

完整性與定位

第 38 行：const FORWARDED_REQUEST_HEADERS

大小：11,956 bytes

SHA-256

3504ec0f62edff8fb176f8d7fe23c7e2bf0ab9eddf4abbcdb96cef8fe8ebc0bb

SRC-045

BT01–BT08及資料流來源模型；僅支持架構關係，當前驗證狀態另依採認索引。

security-assessment/pilot-threat-model.md

完整性與定位

第 62 行：## 5. 信任邊界

大小：24,027 bytes

SHA-256

cc859c9f1a2e9987f7fdabb0e0553a3f221ab73e58aa08b596b0d69fd55795d9

資料截止：截至 Review 45 與 2026-11-09 後續交接文件勘誤。風險接受、產品修補與發布決策未由本報告代行。單檔閱讀不代表完整原始證據隨附。